Handover — Auth Gate 11 foundation (2026-04-26)

This is a single-file handover for the auth work landed in this session. Read it before resuming Gate 11 work, or before flipping `NEXT_PUBLIC_FEATURE_AUTH=true` on staging.

What landed

Eleven PRs merged this session, but the auth slice specifically is:

PR	What
#119	Architecture + BA + PM specs for Gate 11 (planning docs)
#120	Gate 11 foundation: C1–C5 of the 10-commit plan

PR #120 contents:

- **NextAuth v4.24.10** pinned (no caret) with a Credentials provider that POSTs to the existing Django `/api/v1/auth/login/`. No greenfield Django work required — all five accounts/ endpoints already shipped.
- **Server-only DRF token access** via `getServerDrfToken()` in `frontend/lib/auth.ts`. Reads the JWT cookie via `cookies()` from `next/headers` and decodes with `NEXTAUTH_SECRET`. The token never traverses the session callback or `/api/auth/session` JSON, so it's invisible to client components.
- **`apiFetch` authToken option** — additive, back-compat. When set, the Authorization header is `Token <key>`. An explicit `Authorization` header in `headers` wins (escape hatch for the existing service-token `Bearer …` path).
- **Tier-aware SSR forwarding** — the species map and the coordinator dashboard pass `getServerDrfToken()` through to fetchers. The coordinator dashboard's `coordinatorHeaders()` now resolves session-token → `COORDINATOR_API_TOKEN` → no-Authorization in that order, so the existing service-token render path stays as an emergency fallback.
- **`/login` page** at `frontend/app/login/page.tsx` with a server-rendered shell + client form using NextAuth's `signIn("credentials")`. `safeRedirectTarget` allow-list rejects protocol-relative, off-origin, `javascript:`, and `data:` callback URLs.
- **Feature flag scaffold** — `NEXT_PUBLIC_FEATURE_AUTH` defaults off, `frontend/middleware.ts` is a pass-through skeleton with the matcher wired so C8 only fills in the function body.

What's NOT in this PR

The remaining commits in the gate plan are unbuilt:

- **C6** — `/signup` and `/verify` pages, signup → verify-email-sent → click link → activate → redirect-to-login flow.
- **C7** — `/account` page (server-rendered profile, tier badge, Logout button that fires both `signOut()` and `POST /auth/logout/`).
- **C8** — Nav links flag-gated in `SiteHeader` / `NavLinks`, middleware redirect for unauthenticated visits to `/account` and `/dashboard/coordinator`.
- **C9** — Playwright e2e: signup → verify → login → tier-gated read.
- **C10** — Docs: `CLAUDE.md` auth subsection, `OPERATIONS.md` secrets rotation entry.

The PM gate spec (`docs/planning/specs/gate-11-auth-mvp.md`) breaks each one down with primary files. A second implementer can resume from C6 without further planning.

Critical fixes the security review caught

The two reviewers flagged five must-fix issues against the C1–C5 slice before I committed. Three were genuine security holes:

1. **ISR cache poisoning** (security review C1). The map page exported `revalidate = 3600` , and `fetchLocalities` didn't pass `revalidate: 0` when called with `authToken` . A Tier 3+ user's exact-coordinate response would have been cached in Next's shared ISR fetch cache and replayed verbatim to the next anonymous visitor. Fixed two ways: `revalidate: 0` whenever `authToken` is set, and `export const dynamic = "force-dynamic"` on the map page (defense in depth). **Sensitive-species coordinates are the platform's most load-bearing security guarantee — this would have been a real leak.**
2. **`drfToken` leaked via `/api/auth/session`** (security review L1). The session callback was projecting `drfToken` onto the session object, which NextAuth's session endpoint serializes to the browser when a client component calls `useSession()` . Fixed by removing `drfToken` from the session callback and the type augmentation, replaced with a server-only `getServerDrfToken()` that reads the JWT directly.
3. **30-day session vs BA's ≤7-day cap** (security review H1). The BA spec capped session lifetime at 7 days; my initial impl had 30. Fixed to 7.

The other two were code-quality items (`resolveBaseUrl` duplication, inconsistent fetcher signatures) — both addressed in the same commit.

Things that need your attention before merging Gate 11 to prod

These are the items I added to `Alex-ToDo.md` as §1.3 and §1.4:

1. Generate `NEXTAUTH_SECRET` per environment

```
openssl rand -hex 32   # dev → frontend/.env.local
openssl rand -hex 32   # staging → Vercel staging env
openssl rand -hex 32   # prod    → Vercel production env
```

Different value per env; never reuse.

Set `NEXTAUTH_URL` in each env too:

- dev: `http://localhost:3000`
- staging: `https://staging.malagasyfishes.org` (or whatever you wire up)
- prod: `https://malagasyfishes.org`

If you don't, NextAuth falls back to an empty string in JWT signing — dev allows it with a warning, staging and prod refuse to issue cookies.

2. Pick an email-deliverability vendor

Mailgun, Resend, or SendGrid — all have free tiers that cover workshop scale. Resend has the cleanest dashboard; Mailgun is the most battle-tested. Sign up, verify the sending domain, add SPF + DKIM TXT

records. Then point me at the docs and I'll wire `EMAIL_BACKEND` in `backend/config/settings/base.py`.

This is a hard prerequisite for the C6 signup/verify flow to be demoable end-to-end.

3. Verify `getServerDrfToken` actually works on staging

The implementation reads the session cookie, decodes it with `NEXTAUTH_SECRET`, and pulls out `drfToken`. Local dev is fine. Staging has additional surface: the cookie name in prod is `__Secure-next-auth.session-token` (with the `__Secure-` prefix); in dev it's `next-auth.session-token`. The implementation reads both. If staging puts the cookie at a domain that the Next.js runtime can't read (e.g. `.malagasyfishes.org` while the app runs on `staging.malagasyfishes.org`), the token resolution silently fails and the dashboard falls back to `COORDINATOR_API_TOKEN`. Worth verifying once staging is up by:

1. Logging in to staging with a real account.
2. Hitting `https://staging.malagasyfishes.org/dashboard/coordinator` in the browser.
3. Checking the Vercel function logs for the SSR fetch — the `Authorization` header sent to Django should be `Token <user-token>`, not `Bearer <service-token>`.

If it falls back to the service token, something in the cookie domain/name resolution is wrong. The fix is straightforward (set the cookie domain explicitly in `authOptions.cookies`) but worth seeing the real failure mode first rather than guessing.

Things deferred to follow-up commits in Gate 11

Listed in priority order — none are blocking the foundation merge but all need to land before `NEXT_PUBLIC_FEATURE_AUTH` flips on:

- **C6** — `/signup` + `/verify` pages.
- **C7** — `/account` + Logout. The Logout button must fire **both** `POST /api/v1/auth/logout/` (deletes the user's DRF Token from the Django side) **and** NextAuth's `signOut()` (clears the cookie). A logout that only clears the cookie but leaves the DRF Token live is a bug.
- **C8** — Nav-link flag-gating + middleware redirect. Without the middleware, anonymous users can load `/dashboard/coordinator` today (it just falls back to the service-token path and renders empty panels). Not a security hole — Django still gates — but it's confusing UX.
- **C9** — Playwright e2e covering signup → verify → login → tier-gated read. Block on email vendor.
- **C10** — Docs.

Things deferred to Gate 12 (post-ABQ stretch)

- ORCID OAuth provider.
- Account linking ("Connect ORCID" on `/account`).
- Backend `/api/v1/auth/orcid-link/` endpoint.
- A `unique=True` migration on `User.orcid_id`.

ORCID app registration is ~5 minutes when you get there — flag for a post-workshop sprint.

Things deferred indefinitely (or to other gates)

- **Per-user-IP rate limiting forwarding** (security review M2). Today Django throttles `/auth/login/` by IP. On Vercel, all SSR requests come from a small pool of egress IPs, so the throttle collapses to per-frontend-instance. Fix is to forward `X-Forwarded-For` from the NextAuth `authorize()` call

and have Django read it. Real concern but needs a Django-side change. Tracked but not in scope for Gate 11.

- **`COORDINATOR_API_TOKEN` deprecation** (security review M3). The service token has no rotation path or audit trail today. Once user sessions are widespread, deprecate. Tracked for post-Gate-12.
- **MFA, magic-link, institutional SSO**. All explicitly out of scope.

Quick reference

- Architecture spec: `docs/planning/architecture/auth-c-d.md`
- BA stories: `docs/planning/business-analysis/auth-gate-11.md`
- PM gate spec: `docs/planning/specs/gate-11-auth-mvp.md`
- This handover: `docs/handover/auth-gate-11-foundation.md`
- Session cookie names: `__Secure-next-auth.session-token` (prod), `next-auth.session-token` (dev). Both checked by `getServerDrfToken`.
- TTL: tier refresh 5 minutes, session lifetime 7 days rolling.
- Tests: 129 frontend, 568 backend, all green at merge.